

ZEKRO

AUTONOMOUS RED TEAM AUDIT

// EXECUTIVE SECURITY INTELLIGENCE REPORT

[!] ACTIVE EXPLOITATION: ENABLED (LETHAL MODE)

Objetivo: kailu.travel
Fecha: 5/22/2026, 10:54:38 PM
Duración: 364s
Report ID: scan_1779508478871_snsbf3

Resumen Ejecutivo

El motor ofensivo Zekro ha finalizado la auditoría automatizada sobre el objetivo indicado. Se ha recopilado inteligencia técnica y se han identificado un total de 25 vectores de riesgo.

1

CRÍTICOS

1

ALTOS

9

MEDIOS

14

BAJOS / INFO

Inteligencia de Amenazas y Hallazgos

[CRÍTICO] HTTP Request Smuggling

Módulo: HTTP_SMUGGLING_CL_TE | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

CL.TE request smuggling detected. Frontend uses Content-Length, backend uses Transfer-Encoding. Attacker can inject arbitrary requests that bypass frontend security.

[Impacto Real]: La infraestructura es vulnerable a desincronización de peticiones HTTP entre frontend y backend. Un atacante puede inyectar peticiones que el backend interpreta como de otro usuario, permitiendo robo de sesiones, bypass de WAF y acceso a datos de terceros.

Estrategia de Remediación (Playbook):

Normalizar el parsing HTTP en todos los proxies. Deshabilitar keep-alive entre capas si hay incompatibilidad. Actualizar servidores web.

[ALTO] HTTP Request Smuggling

Módulo: HTTP_SMUGGLING_TE_TE | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

TE.TE obfuscation successful (Transfer-Encoding: chunked).

[Impacto Real]: La infraestructura es vulnerable a desincronización de peticiones HTTP entre frontend y backend. Un atacante puede inyectar peticiones que el backend interpreta como de otro usuario, permitiendo robo de sesiones, bypass de WAF y acceso a datos de terceros.

Estrategia de Remediación (Playbook):

Reject malformed Transfer-Encoding headers.

[MEDIO] DNSSEC No Habilitado

Módulo: NO_DNSSEC | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

DNSSEC not enabled. Domain is vulnerable to DNS spoofing/cache poisoning attacks.

[Impacto Real]: La zona DNS carece de firma criptográfica. Un atacante con acceso a nivel de red (ISP, Wi-Fi corporativo) puede interceptar consultas DNS y redirigir el tráfico hacia servidores bajo su control, clonando la interfaz para robar credenciales de forma masiva e indetectable.

Estrategia de Remediación (Playbook):

Activar DNSSEC en el registrador del dominio. Verificar propagación con herramientas como DNSViz.

[MEDIO] DKIM No Detectado

Módulo: DKIM_NOT_DETECTED | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Cryptographic Signature Missing (DKIM). Domain payload authenticity cannot be mathematically verified.

[Impacto Real]: Los correos del dominio no llevan firma criptográfica DKIM. Los servidores receptores no pueden verificar que el correo realmente fue enviado por la empresa. Los atacantes falsifican correos idénticos para phishing, fraude financiero y robo de datos de clientes.

Estrategia de Remediación (Playbook):

Generar par de claves DKIM, publicar la clave pública en DNS y configurar la firma automática en el servidor de correo.

[MEDIO] Puerto de Servicio Expuesto

Módulo: open_port | Objetivo Afectado: kailu.travel:80

Análisis de Riesgo y Contexto de Negocio:

Naabu discovered open port 80 on kailu.travel.

[Impacto Real]: Se detectaron puertos abiertos con servicios accesibles desde internet. Puertos como 22 (SSH), 3306 (MySQL), 5432 (PostgreSQL) o 6379 (Redis) expuestos permiten ataques de fuerza bruta directos y, si el servicio tiene vulnerabilidades, ejecución remota de código.

Estrategia de Remediación (Playbook):

Ensure the port is intended to be publicly exposed and is properly secured.

[MEDIO] Puerto de Servicio Expuesto

Módulo: open_port | Objetivo Afectado: kailu.travel:443

Análisis de Riesgo y Contexto de Negocio:

Naabu discovered open port 443 on kailu.travel.

[Impacto Real]: Se detectaron puertos abiertos con servicios accesibles desde internet. Puertos como 22 (SSH), 3306 (MySQL), 5432 (PostgreSQL) o 6379 (Redis) expuestos permiten ataques de fuerza bruta directos y, si el servicio tiene vulnerabilidades, ejecución remota de código.

Estrategia de Remediación (Playbook):

Ensure the port is intended to be publicly exposed and is properly secured.

[MEDIO] Puerto de Servicio Expuesto

Módulo: open_port | Objetivo Afectado: kailu.travel:80

Análisis de Riesgo y Contexto de Negocio:

Naabu discovered open port 80 on kailu.travel.

[Impacto Real]: Se detectaron puertos abiertos con servicios accesibles desde internet. Puertos como 22 (SSH), 3306 (MySQL), 5432 (PostgreSQL) o 6379 (Redis) expuestos permiten ataques de fuerza bruta directos y, si el servicio tiene vulnerabilidades, ejecución remota de código.

Estrategia de Remediación (Playbook):

Ensure the port is intended to be publicly exposed and is properly secured.

[MEDIO] Puerto de Servicio Expuesto

Módulo: open_port | Objetivo Afectado: kailu.travel:443

Análisis de Riesgo y Contexto de Negocio:

Naabu discovered open port 443 on kailu.travel.

[Impacto Real]: Se detectaron puertos abiertos con servicios accesibles desde internet. Puertos como 22 (SSH), 3306 (MySQL), 5432 (PostgreSQL) o 6379 (Redis) expuestos permiten ataques de fuerza bruta directos y, si el servicio tiene vulnerabilidades, ejecución remota de código.

Estrategia de Remediación (Playbook):

Ensure the port is intended to be publicly exposed and is properly secured.

[MEDIO] Vulnerabilidad DNS

Módulo: dns | Objetivo Afectado: kailu.travel

Análisis de Riesgo y Contexto de Negocio:

DNSSEC not enabled. Domain is vulnerable to DNS spoofing/cache poisoning attacks.

[Impacto Real]: La configuración DNS presenta debilidades: transferencia de zona habilitada, registros obsoletos, subdominios huérfanos o resolvers abiertos. Los atacantes usan esto para mapear toda la infraestructura, ejecutar subdomain takeover o lanzar ataques de amplificación DDoS.

Estrategia de Remediación (Playbook):

Enable DNSSEC for your domain.

[MEDIO] Detección de WAF/Firewall

Módulo: waf | Objetivo Afectado: https://kailu.travel

Análisis de Riesgo y Contexto de Negocio:

No Web Application Firewall was detected protecting this application.

[Impacto Real]: Se detectó la presencia (o ausencia) de un Web Application Firewall. Si no hay WAF, la aplicación está directamente expuesta a ataques automatizados (SQLi, XSS, bots). Si hay WAF pero está mal configurado, los atacantes pueden evadir sus reglas.

Estrategia de Remediación (Playbook):

Consider deploying a WAF (Cloudflare, AWS WAF, ModSecurity) to protect against common web attacks.

[MEDIO] Riesgo de HTTP/2 Smuggling

Módulo: H2_DOWNGRADE_RISK | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Server supports HTTP/2 but backend may use HTTP/1.1 (Downgrade risk).

[Impacto Real]: El frontend habla HTTP/2 pero el backend usa HTTP/1.1. Esta desincronización permite "HTTP Request Smuggling": el atacante inyecta peticiones fantasma que el backend procesa como legítimas, pudiendo acceder a sesiones de otros usuarios o bypassar controles de seguridad.

Estrategia de Remediación (Playbook):

Ensure strict validation during protocol translation.

[BAJO] SPF FAILURE

Módulo: SPF_FAILURE | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Authentication Failure: Missing SPF. Critical risk of Corporate Spoofing & Phishing.

[Nota de Análisis]: Se detectó un hallazgo que requiere revisión manual. Asegúrese de evaluar su impacto real en el contexto de su arquitectura antes de considerarlo un riesgo crítico.

Estrategia de Remediación (Playbook):

1. Revisar la configuración del componente SPF_FAILURE.
2. Validar manualmente la existencia y el riesgo real de la vulnerabilidad.
3. Aplicar medidas de mitigación o marcaje como falso positivo según corresponda.

[BAJO] DMARC Débil o Ausente

Módulo: DMARC_FAILURE | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Missing DMARC Policy. Domain is entirely unprotected against Direct-Domain Spoofing.

[Impacto Real]: Sin política DMARC estricta, los servidores de correo no saben qué hacer con emails falsificados. Los atacantes lanzan campañas masivas de phishing usando el dominio de la empresa sin que el equipo de seguridad reciba ninguna alerta.

Estrategia de Remediación (Playbook):

Implementar DMARC progresivamente: p=none (monitoreo) !' p=quarantine !' p=reject.

[BAJO] MX RECORD MISSING

Módulo: MX_RECORD_MISSING | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Mail Exchanger (MX) routing missing. Domain incapable of receiving telemetry or correspondence.

[Nota de Análisis]: Se detectó un hallazgo que requiere revisión manual. Asegúrese de evaluar su impacto real en el contexto de su arquitectura antes de considerarlo un riesgo crítico.

Estrategia de Remediación (Playbook):

1. Revisar la configuración del componente MX_RECORD_MISSING.
2. Validar manualmente la existencia y el riesgo real de la vulnerabilidad.
3. Aplicar medidas de mitigación o marcaje como falso positivo según corresponda.

[BAJO] Cabecera de Seguridad Faltante

Módulo: missing_header | Objetivo Afectado: <https://kailu.travel>

Análisis de Riesgo y Contexto de Negocio:

Inadequate defense-in-depth: Controls which resources can be loaded.

[Impacto Real]: Cabeceras HTTP críticas como Content-Security-Policy, X-Frame-Options o Strict-Transport-Security no están presentes. Sin ellas, el navegador del usuario no tiene instrucciones de seguridad y queda vulnerable a XSS, clickjacking y downgrade attacks.

Estrategia de Remediación (Playbook):

Deploy "content-security-policy" header at edge/proxy to mitigate client-side exploitation vectors.

[BAJO] Cabecera de Seguridad Faltante

Módulo: missing_header | Objetivo Afectado: <https://kailu.travel>

Análisis de Riesgo y Contexto de Negocio:

Inadequate defense-in-depth: Legacy XSS filter. Modern browsers use CSP instead, but still good practice.

[Impacto Real]: Cabeceras HTTP críticas como Content-Security-Policy, X-Frame-Options o Strict-Transport-Security no están presentes. Sin ellas, el navegador del usuario no tiene instrucciones de seguridad y queda vulnerable a XSS, clickjacking y downgrade attacks.

Estrategia de Remediación (Playbook):

Deploy "x-xss-protection" header at edge/proxy to mitigate client-side exploitation vectors.

[BAJO] Fuga de Información

Módulo: info_leak | Objetivo Afectado: <https://kailu.travel>

Análisis de Riesgo y Contexto de Negocio:

The Server header reveals your web server software and version.

[Impacto Real]: El servidor expone datos internos: versiones de software, rutas del filesystem, stack traces de error o archivos de configuración. Los atacantes recopilan esta información para diseñar ataques precisos contra las versiones y componentes específicos identificados.

Estrategia de Remediación (Playbook):

Remove or obfuscate the Server header.

[BAJO] TLS 1.3 No Soportado

Módulo: NO_TLS13 | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

TLS 1.3 not supported. Recommended for best security and performance.

[Impacto Real]: El servidor no soporta TLS 1.3, el estándar más seguro y rápido. Se pierde protección contra ataques de downgrade y el handshake es más lento. Clientes modernos priorizan TLS 1.3; no soportarlo degrada seguridad y rendimiento.

Estrategia de Remediación (Playbook):

Actualizar la configuración del servidor web para habilitar TLS 1.3 junto con TLS 1.2.

[INFO] Supabase Anon Key & URL Exposed in Frontend

Módulo: js_secret_exposure | Objetivo Afectado: https://kailu.travel/assets/index-D_TYK3nC.js

Análisis de Riesgo y Contexto de Negocio:

Anomalía detectada en js_secret_exposure.

[Nota de Análisis]: Se detectó un hallazgo que requiere revisión manual. Asegúrese de evaluar su impacto real en el contexto de su arquitectura antes de considerarlo un riesgo crítico.

Estrategia de Remediación (Playbook):

Verify that robust RLS policies are enforced on all Supabase tables. No action needed if RLS is configured correctly.

[INFO] Subdominios Descubiertos: 1

Módulo: subdomains | Objetivo Afectado: kailu.travel

Análisis de Riesgo y Contexto de Negocio:

Anomalía detectada en subdomains.

[Nota de Análisis]: Se detectó un hallazgo que requiere revisión manual. Asegúrese de evaluar su impacto real en el contexto de su arquitectura antes de considerarlo un riesgo crítico.

Estrategia de Remediación (Playbook):

Review subdomains for orphaned or forgotten infrastructure.

[INFO] Reconocimiento DNS Exitoso

Módulo: dns_info | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

3 record types resolved. Grade: A

[Impacto Real]: El escaneo DNS reveló información detallada sobre la infraestructura: servidores de correo, subdominios internos, registros TXT con tokens de verificación. Los atacantes usan esta inteligencia para planificar ataques dirigidos contra servicios específicos.

Estrategia de Remediación (Playbook):

Informational — review DNS configuration for best practices.

[INFO] Calificación TLS Baja

Módulo: `tls_grade` | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

Protocol: N/A, Cipher: N/A

[Impacto Real]: La configuración TLS del servidor recibió una calificación insuficiente. Esto indica múltiples debilidades combinadas: protocolos obsoletos, cifrados débiles y configuración subóptima que en conjunto facilitan la interceptación del tráfico cifrado.

Estrategia de Remediación (Playbook):

Aim for grade A or higher.

[INFO] Puerto de Servicio Expuesto

Módulo: `open_port` | Objetivo Afectado: `kailu.travel:80`

Análisis de Riesgo y Contexto de Negocio:

Servidor detectado: Netlify

[Impacto Real]: Se detectaron puertos abiertos con servicios accesibles desde internet. Puertos como 22 (SSH), 3306 (MySQL), 5432 (PostgreSQL) o 6379 (Redis) expuestos permiten ataques de fuerza bruta directos y, si el servicio tiene vulnerabilidades, ejecución remota de código.

Estrategia de Remediación (Playbook):

No requiere acción. Es un puerto estándar necesario para el funcionamiento web.

[INFO] Puerto de Servicio Expuesto

Módulo: open_port | Objetivo Afectado: kailu.travel:443

Análisis de Riesgo y Contexto de Negocio:

Servidor detectado: Netlify

[Impacto Real]: Se detectaron puertos abiertos con servicios accesibles desde internet. Puertos como 22 (SSH), 3306 (MySQL), 5432 (PostgreSQL) o 6379 (Redis) expuestos permiten ataques de fuerza bruta directos y, si el servicio tiene vulnerabilidades, ejecución remota de código.

Estrategia de Remediación (Playbook):

No requiere acción. Es un puerto estándar necesario para el funcionamiento web.

[INFO] Configuración TLS Deficiente

Módulo: TLS_TIMEOUT | Objetivo Afectado: N/A

Análisis de Riesgo y Contexto de Negocio:

TLS audit interrupted (Connection Refused / Rate-Limiting Timeout). Cannot definitively assess TLS state. Target may have active WAF.

[Impacto Real]: El servidor permite cipher suites débiles, no soporta Perfect Forward Secrecy o tiene configuración TLS subóptima. Los atacantes pueden descifrar tráfico interceptado retroactivamente si obtienen la clave privada del servidor.

Estrategia de Remediación (Playbook):

Configurar cipher suites modernos con PFS (ECDHE). Deshabilitar cifrados CBC y RC4. Usar [ssl-config.mozilla.org](https://config.mozilla.org) como referencia.

Conclusión Ejecutiva y Calificación de Riesgo

76

RISK SCORE /100

ALTO

DESGLOSE DE IMPACTO

% 1 hallazgos críticos !' Explotación inmediata posible

% 1 hallazgos altos !' Compromiso probable sin remediación

% 9 hallazgos medios !' Vectores de escalamiento lateral

% 14 hallazgos bajos !' Endurecimiento recomendado

Total: 25 vectores identificados

La infraestructura evaluada presenta un nivel de exposición ALTO. Aunque no se detectaron vectores de compromiso inmediato con máxima severidad, la combinación de hallazgos altos y medios genera una superficie de ataque significativa. Se recomienda un plan de remediación priorizado en un horizonte de 1-2 semanas para los hallazgos altos, con seguimiento mensual para los medios.

Matriz de Priorización de Remediación

0-48 horas	Críticos	Vectores con explotación activa o impacto directo en datos sensibles.
1-2 semanas	Altos	Vulnerabilidades con exploits públicos disponibles o acceso privilegiado.
30 días	Medios	Configuraciones incorrectas y vectores de escalamiento.
Trimestral	Bajos / Info	Mejoras de endurecimiento y mejores prácticas.

Este reporte fue generado de forma automatizada por el motor ofensivo Zekro. Los hallazgos reflejan el estado de la infraestructura al momento de la evaluación. Se recomienda reevaluar después de cada ciclo de remediación.